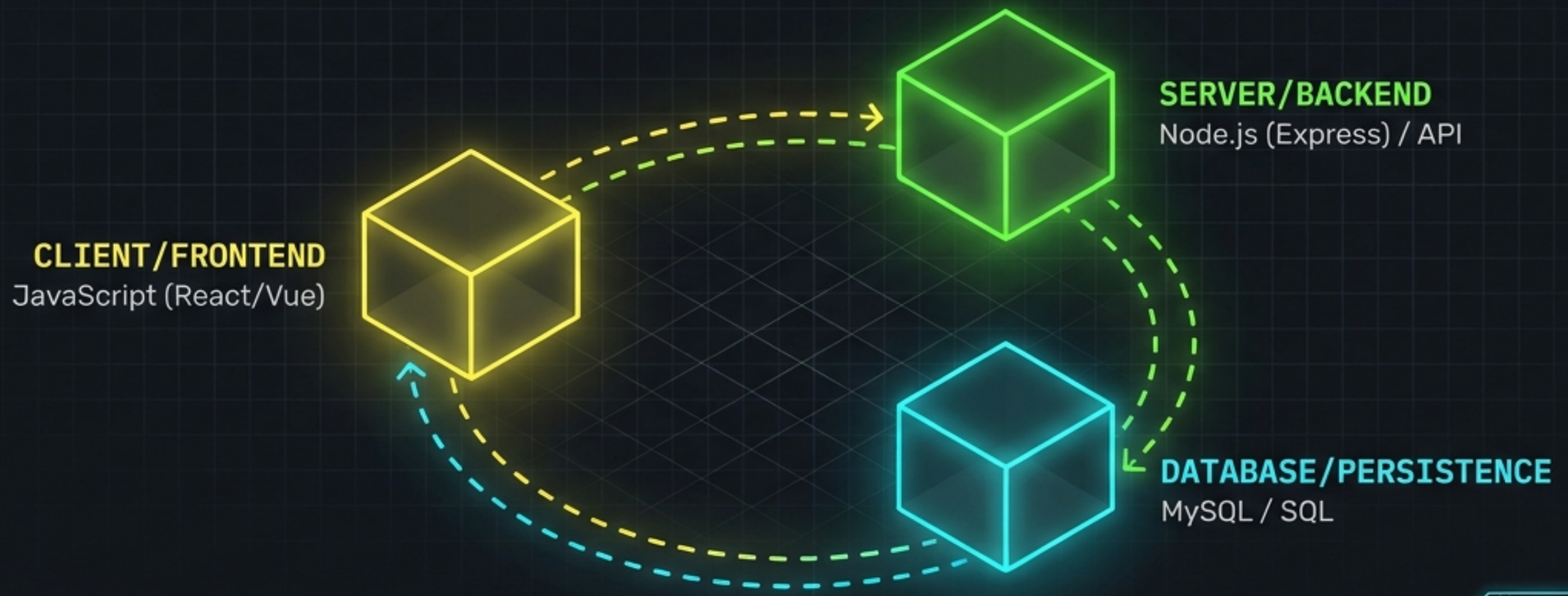
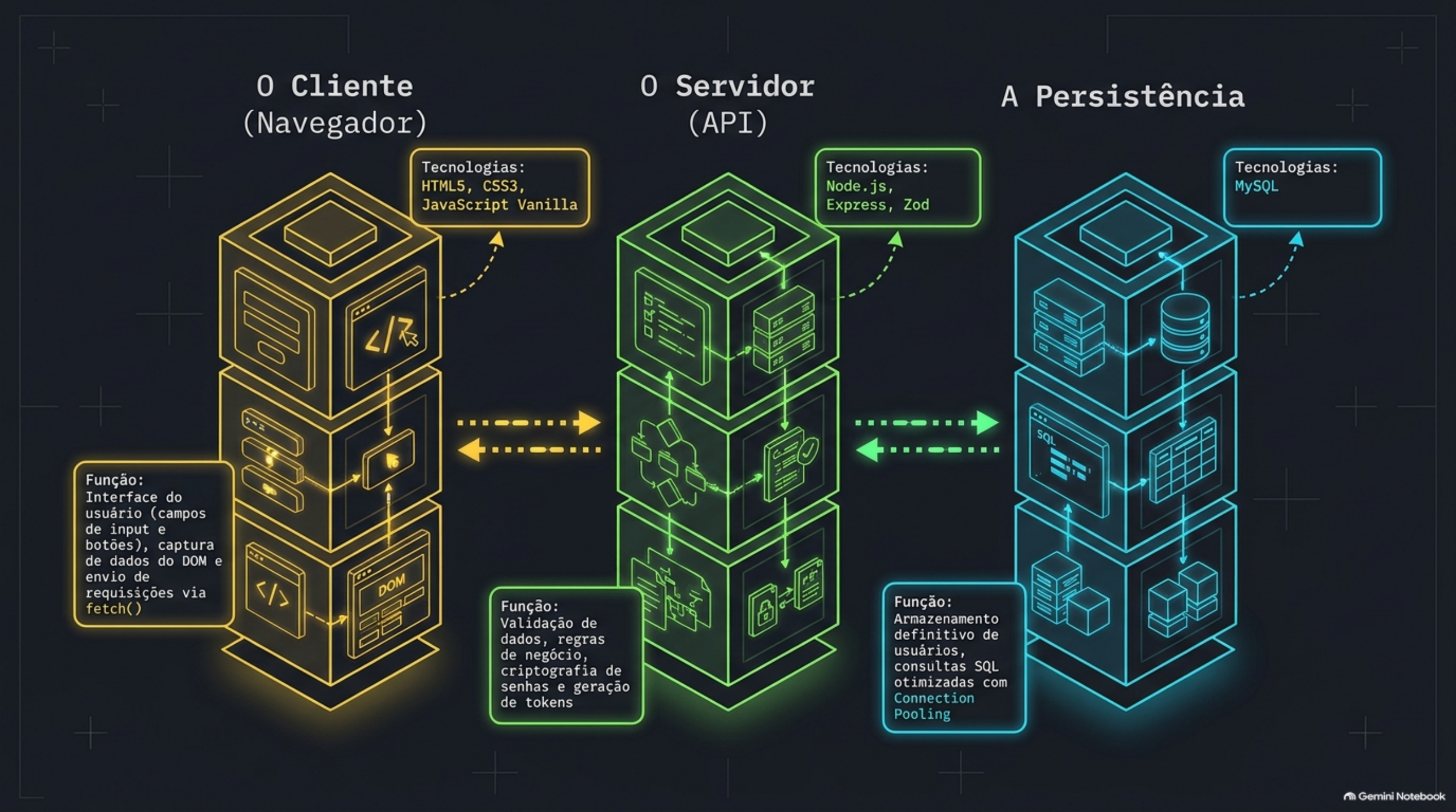
O Roadmap Full-Stack

Construindo seu 1º Sistema de Login Seguro com JavaScript, Node.js e MySQL



[Manual de Arquitetura]

Gemini Notebook



Gemini Notebook

A Estrutura do Projeto



View: Arquivos estáticos (HTML/CSS/JS). Onde a interação visual acontece.

Rotas: O mapa da sua API. Define os endpoints (ex: POST /api/auth/login).

Controller: O cérebro. Recebe a requisição, processa a lógica de login/cadastro e devolve a resposta.

Model: O mensageiro do banco. O único lugar onde comandos SQL devem ser escritos.

Filtros: Guardas de segurança (validação, verificação de token) antes do Controller.

Gemini Notebook

Foco de Estudo: DOM e Assincronicidade



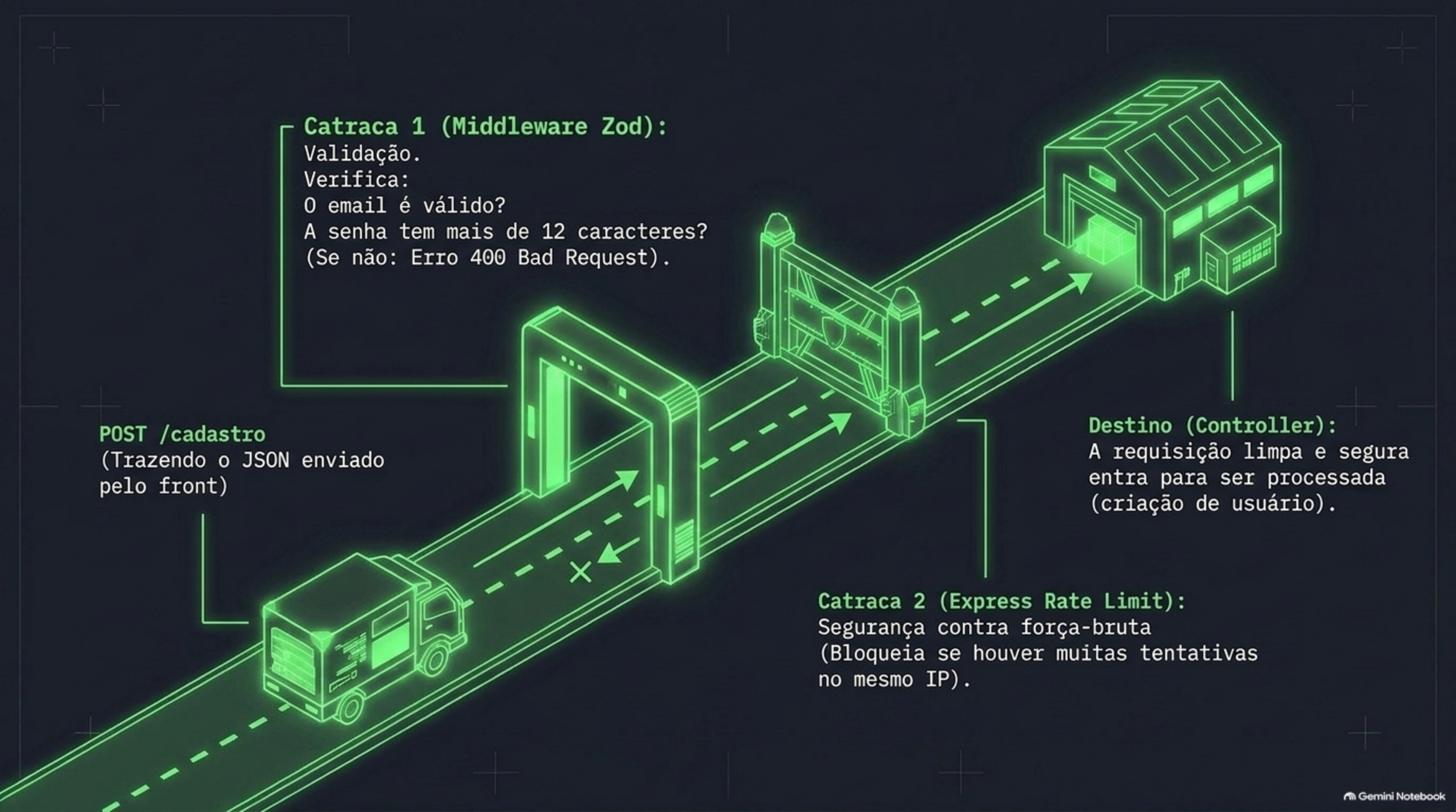
Interação com o DOM - extraindo o dado visual

```
const email = document.querySelector('#email').value;
```

A mágica do Fetch API - enviando JSON de forma assíncrona para o Backend

```
const resposta = await fetch('/api/auth/login', {
  method: 'POST',
  headers: { 'Content-Type': 'application/json' },
  body: JSON.stringify({ email, senha })
});
```

Gemini Notebook



Gemini Notebook

Tabela usuarios
id (INT, Primary Key)
email (VARCHAR, Unique)
senha_hash (VARCHAR)
papel (ENUM)

O Mandamento do SQL: Nunca concatene variáveis no texto do SQL.

```
const [rows] = await pool.execute(
  'SELECT * FROM usuarios WHERE email = ?',
  [email]
);
```

As interrogações (?) garantem que o banco trate o input do usuário estritamente como dado, impedindo execução de código malicioso. Utilizar mysql2/promise para Connection Pooling.

Gemini Notebook



Autenticação

Pergunta Central: Quem é você?

O que é: O processo de provar a identidade do usuário.

Como aplicamos: Verificação de e-mail e senha no banco de dados durante o login.



Autorização

Pergunta Central: O que você pode fazer?

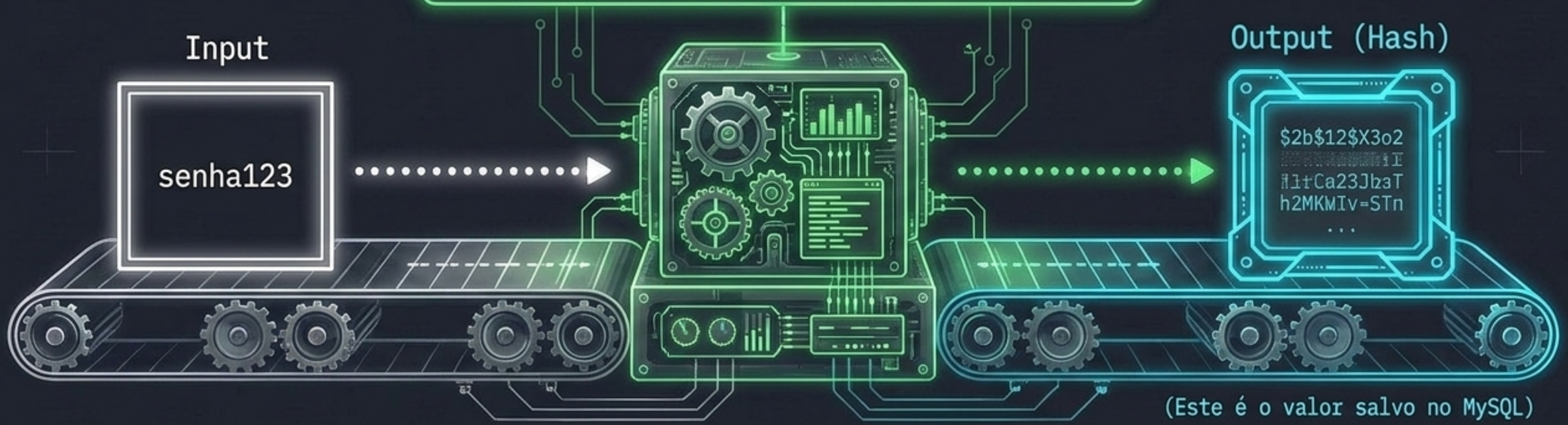
O que é: O mecanismo de restringir acesso a recursos específicos.

Como aplicamos: Perfis (Roles) como USUARIO vs ADMIN. (Ex: Apenas um Admin pode acessar a rota de deletar registros).

Gemini Notebook

O Segredo das Senhas (Bcrypt)

Processamento (Cost = 12 + Salt): A máquina adiciona caracteres aleatórios (Salt) e processa o dado 12 vezes, custando poder de CPU de propósito para evitar ataques brute-force.



Regra de Ouro: O Hash é irreversível. No login, não decriptamos a senha; usamos bcrypt.compare(senhaDigitada, hashSalvo) para checar se a senha bate.

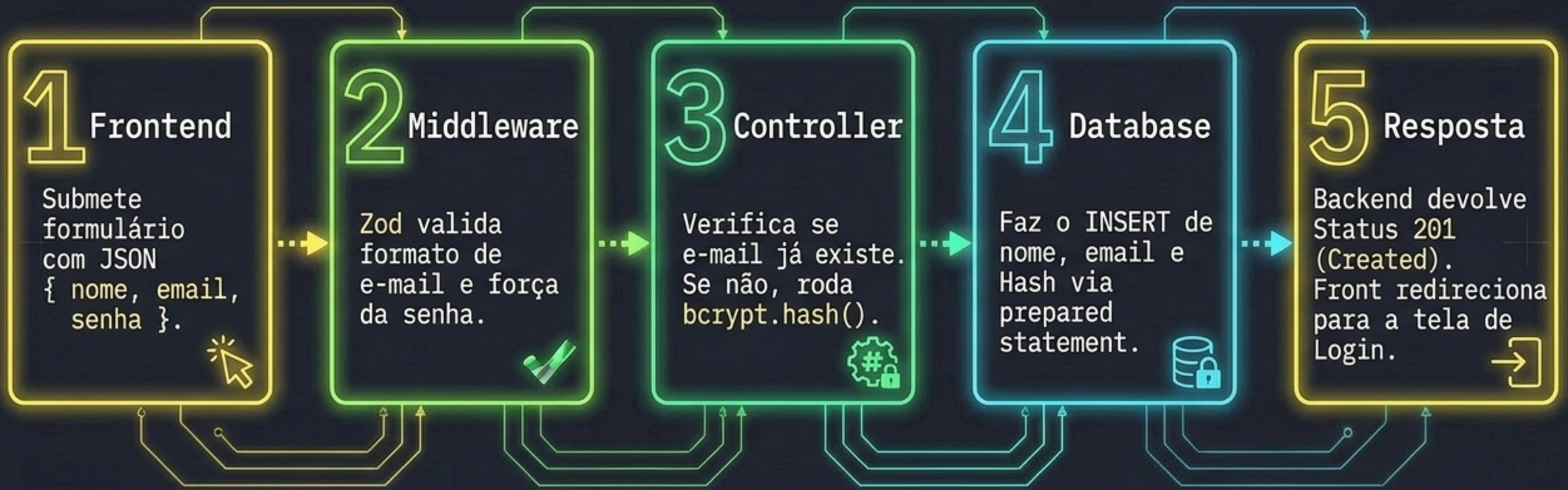
Gemini Notebook

A Chave do Acesso (JSON Web Token)



Gemini Notebook

O Fluxo de Cadastro - POST /cadastro



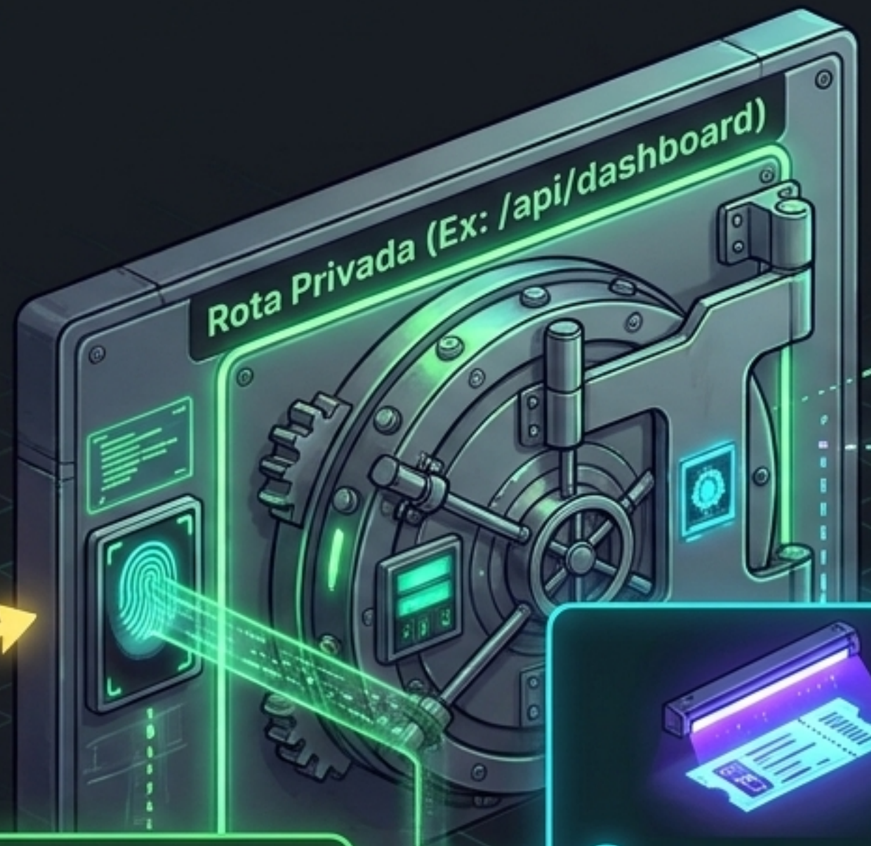
Gemini Notebook

O Fluxo de Login - POST /login



Gemini Notebook

Acessando uma Rota Protegida



1 Requisição

Cliente tenta fazer um GET. O navegador envia os cookies automaticamente.

2 Intercepção

O middleware de segurança intercepta a requisição e lê o cookie de token.

3 Verificação

`jwt.verify()` confere a assinatura usando o `JWT_SECRET` do `.env`. Se o token expirar (ex: após 15 min), a verificação falha.

4 Decisão

[Caminho A]: Assinatura falsa/expirada? Retorna `401 Unauthorized`.

[Caminho B]: Assinatura válida? Adiciona os dados ao objeto request e passa para o controller (`next()`).

401

Gemini Notebook

FAÇA (Do’s)

Use `Connection Pools` para não esgotar as conexões do banco.

Valide o input no backend sempre (mesmo tendo validado no HTML).

Utilize recursos modernos (Express 5 repassa erros assíncronos automaticamente, sem precisar de try/catch em toda rota).

EVITE (Don’ts)

NUNCA versione seu arquivo `.env` (Use `.gitignore`).

NUNCA retorne erros brutos de SQL para o cliente (Isso vaza detalhes da estrutura da sua tabela).

NUNCA concatene variáveis diretamente na string SQL (`WHERE email = ' + email + '`).

Gemini Notebook

Seu Checklist de Batalha

- [x] **1. Infraestrutura**
  Criar o Banco MySQL (`CREATE TABLE`) e configurar o arquivo `.env`.



- [x] **2. Conexão** Configurar Node/Express e o `mysql2/promise` (Pool).



- [ ] **3. Os Models** Escrever as funções limpas de SQL (buscar por email, criar usuário).



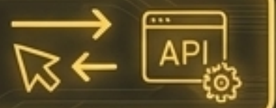
- [x] **4. Autenticação** Codificar os Middlewares e o Controller (Bcrypt + Zod + JWT).



- [x] **5. A Interface** Construir o HTML/CSS semântico e formulários.

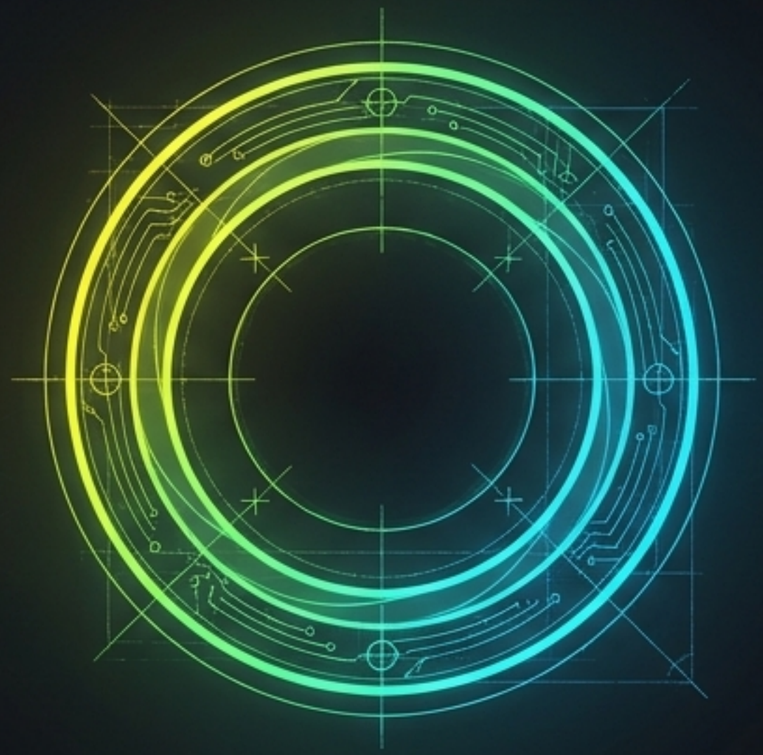


- [ ] **6. A Integração** Usar **fetch()** no front-end para plugar a UI na sua nova API.



Gemini Notebook

O Código Está em Suas Mãos



Um sistema completo não é feito de ferramentas complexas, mas da soma de fundamentos bem estruturados. Você entende os blocos. Você conhece os fluxos. Abra o editor de código e comece a construir.

`Inicializar Projeto (npm run dev)_`

Gemini Notebook